

Защита контроллера домена предприятия

Лабораторная работа №1 · Киберполигон Ampire

Назармамадов Умед Джумаевич

2026-10-06

Содержание I

- 1 Информация
- 2 Вводная часть
- 3 Расследование и устранение
- 4 Результаты

Раздел 1

Информация

- Назармамадов Умед Джумаевич
- студент, группа НФИбд-02-23
- Российский университет дружбы народов
- курс «Защита сетей и кибербезопасность»
- umednazarmamadov40@gmail.com

Раздел 2

Вводная часть

- **Цель:** расследовать инцидент на киберполигоне Ampire (сценарий №2 «Защита контроллера домена предприятия») и устранить все уязвимости.
- **Задачи:**
 - обнаружить этапы атаки по данным ViPNet IDS NS;
 - задокументировать каждый этап карточкой инцидента;
 - устранить причину уязвимости на поражённом узле;
 - подтвердить устранение по статусу полигона.

Сценарий атаки

Этап	Действие	Источник → Цель
1	SQL-инъекция → meterpreter	Kali → Web Server PHP (10.10.1.20)
2	Фишинг → meterpreter	Kali → Admin Workstation (10.10.4.10)
3	Перебор пароля RDP → захват AD	Web Server PHP → MS AD (10.10.2.10)

Внешний атакующий закрепляется на периметре и движется вглубь сети к контроллеру домена.

Раздел 3

Расследование и устранение

Уязвимость 1. SQL-инъекция

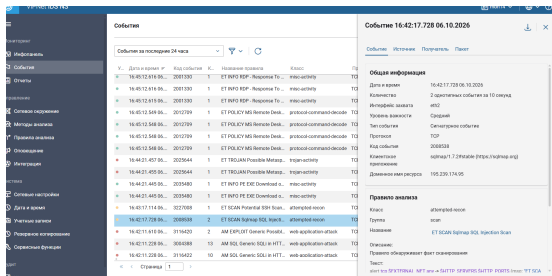


Рисунок 1: Событие ViPNet IDS NS: sqlmap-сканирование

- Карточка: источник Kali (195.239.174.11), актив Web Server PHP
- Устранение: ss -K убита сессия, в NewsController.php добавлена валидация is_numeric(\$id)
- Попутно обнаружен и остановлен туннель chisel на сервере

Карточка инцидента №1

Основная информация

Чат

Новый

Основная информация

Дата и время события

06.10.2026 16:42

Описание

Зафиксировано сканирование веб-сервера PHP (195.239.174.95/10.10.1.20) с помощью sqlmap 1.7.2 с IP 195.239.174.11. Выявлен уязвимый параметр, впоследствии использованный для загрузки вредоносного файла.

Индикаторы компрометации

attempted-recon/sqlmap

Рекомендации

Добавить валидацию входных параметров (is_numeric для id), заблокировать 195.239.174.11, завершить активные сессии с данным адресом.

Оценка

☆☆☆☆

Автор

Н Назармамадов Умед @1032225205

Ответственный

Ничего не выбрано

Источник

195.239.174.11 (Kali) x

Поражённые активы

10.10.1.20 (Web Server PHP) x

Рисунок 2: Заполненная карточка: SQL-инъекция

Уязвимость 2. Компрометация рабочей станции администратора

События					
События за последние 24 часа					
У.	Дата и время ст.	Код события	И.	Название процесса	Класс
■	16:45:12.615 sec.	2001350	1	ET INFO-RDP - Response To	misc-activity
■	16:45:12.615 sec.	2001350	1	ET INFO-RDP - Response To	misc-activity
■	16:45:12.615 sec.	2001350	1	ET INFO-RDP - Response To	misc-activity
■	16:45:12.549 sec.	2012709	1	ET POLICY MS Remote Desk.	protocol-command-decode
■	16:45:12.548 sec.	2012709	1	ET POLICY MS Remote Desk.	protocol-command-decode
■	16:45:12.548 sec.	2012709	1	ET POLICY MS Remote Desk.	protocol-command-decode
■	16:45:12.548 sec.	2012709	1	ET POLICY MS Remote Desk.	protocol-command-decode
■	16:44:21.457 sec.	3025644	1	ET TROJAN Possible Metasp.	trojan-activity
■	16:44:21.455 sec.	3025644	1	ET TROJAN Possible Metasp.	trojan-activity
■	16:44:21.445 sec.	3035480	1	ET INFO PEX ERT download o	misc-activity
■	16:44:21.445 sec.	3035480	1	ET INFO PEX ERT download o	misc-activity
■	16:43:17.114 sec.	3227006	1	ET SCAN Potential SSH scan	attempted-recon
■	16:42:27.728 sec.	2098538	2	ET SCAN Sqlmap SQL inject.	attempted-recon
■	16:42:11.610 sec.	3116420	2	AM EXPLOIT Generic Posix s	web-application-attack
■	16:42:11.610 sec.	3040888	1	AM SQL Generic SQL in HTT	web-application-attack
■	16:42:11.728 sec.	3116420	2	AM SQL Generic SQL in HTT	web-application-attack

Рисунок 3: Событие ViPNet IDS NS: Metasploit payload

- Фишинговое письмо → meterpreter-сессия на Admin Workstation
- Устранение: taskkill сессии, включён Windows Defender (DisableAntiSpyware, DisableRealtimeMonitoring убраны из реестра), перезапущена служба WinDefend
- Подтверждено: RealTimeProtectionEnabled = True, AntivirusEnabled = True

Карточка инцидента №2

Основная информация

Чат

Новый

Основная информация

Дата и время события

06.10.2026 16:44

Описание

Закреплено сетевая активность, характерная для Metasploit Payload (Bind-API from server) между атакующим 195.239.174.11 и рабочей станцией администратора 10.10.4.10. Свидетельствует об успешной компрометации узла через фишинговое письмо с вредоносным вложением

Индикаторы компрометации

trojan-activity/Metasploit Payload

Рекомендации

Завершить сессию с атакующим (netstat-ano+taskkill), включить Real-time Protection Windows Defender, провести полное сканирование узла

Оценка

☆☆☆☆☆

Автор

Н Назармамадов Умед @1032225205

Ответственный

Ничего не выбрано

Источник

195.239.174.11 (Kali) x

Поражённые активы

10.10.4.10 (Administrator Workstation) x

Рисунок 4: Заполненная карточка: компрометация рабочей станции

Уязвимость 3. Захват контроллера домена

События
Событие 16:45:23.549 06.10.2026

У.	Дата и время г.	Код события	К.	Название правила	Компо	Тр
*	16:51:28.778 g.	2100538	1	GPL NETBOS SMB IPCS un...	protocol-command-decode	TCP
*	16:50:58.667 g.	2100538	1	GPL NETBOS SMB IPCS un...	protocol-command-decode	TCP
*	16:50:28.644 g.	2100538	1	GPL NETBOS SMB IPCS un...	protocol-command-decode	TCP
*	16:49:58.576 g.	2100538	1	GPL NETBOS SMB IPCS un...	protocol-command-decode	TCP
*	16:48:00.643 g.	3227018	1	ET SCAN Behavioral Unusual...	network-scan	TCP
*	16:45:49.352 g.	2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCP
*	16:45:48.351 g.	2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCP
*	16:45:48.343 g.	2025480	1	ET INFO PE EXE Download o...	neta-activity	TCP
*	16:45:49.343 g.	2025480	1	ET INFO PE EXE Download o...	neta-activity	TCP
*	16:45:23.617 g.	2011393	18	ET INFO RDP - Response To...	neta-activity	TCP
*	16:45:23.549 g.	2011393	29	ET POLICY MS Remote Desk...	protocol-command-decode	TCP
*	16:45:12.994 g.	3007793	1	AM SCAN Microsoft Window...	unclassified-user	TCP
*	16:45:12.964 g.	3227018	1	ET SCAN Behavioral Unusual...	network-scan	TCP
*	16:45:12.964 g.	3227023	1	ET SCAN Behavioral Unusual...	neta-activity	TCP
*	16:45:12.616 g.	2011393	1	ET INFO RDP - Response To...	neta-activity	TCP

<
Страница 1
>

Рисунок 5: Событие ViPNet IDS NS: brute-force по RDP

- 29 запросов аутентификации за 10 секунд с уже скомпрометированного Web Server PHP на MS AD
- Устранение: удалена нелегитимная учётная запись hacker (Remove-ADUser), сменён пароль администратора домена (net user Administrator *)

Карточка инцидента №3

Основная информация

Чат

Новый ▾

Основная информация

Дата и время события ⓘ

06.10.2026 16:45

Описание ⓘ

С уже скомпрометированного узла 10.10.1.20 зафиксирован массовый перебор пароля администратора домена по RDP (порт 3389) на контроллер домена 10.10.2.10. Множественные запросы аутентификации за короткий промежуток времени (29 за 10 сек) свидетельствует об атаке типа brute-force. Непосредственно после зафиксировано активность Metasploit на этом же направлении, что указывает на успешный захват учётной записи и закрепление на AD

Индикаторы компрометации ⓘ

protocol-command-decode/MS Remote Desktop Administrator Login Request/brute-force

Рекомендации ⓘ

Сменить пароль администратора AD на сложный, проверить и удалить все добавленные нарушителем учётные записи в Active Directory Users and Computers, ограничить доступ по RDP к контроллеру домена только с доверенных узлов

Оценка

☆☆☆☆☆

Автор

Н

Назармамадов Умед
@1032225205

Ответственный

Ничего не выбрано ▾

Источник ⓘ

10.10.1.20 (Web Server PHP) x ▾

Поражённые активы ⓘ

10.10.2.10 (MS Active Directory) x ▾

Раздел 4

Результаты

Итоговые статусы

Уязвимость	Узел	Статус
SQL Injection	Web Server PHP	Устранено
Web portal meterpreter	Web Server PHP	Устранено
Windows Defender	Admin Workstation	Устранено (подтверждено командами)
Admin meterpreter	Admin Workstation	Устранено
AD Admin Password	MS Active Directory	Устранено
AD user	MS Active Directory	Устранено

Устранение одной уязвимости не останавливает атакующего, уже закрепившегося на другом узле: только последовательное закрытие всей цепочки — от периметра до контроллера домена — реально останавливает атаку.